API Security Risk Analysis Report

Executive Summary

This report presents a read-only security assessment of a public demo API to identify common API security risks found in modern SaaS platforms, mobile applications, and web services.

The assessment focused on publicly accessible endpoints, authentication controls, exposed response data, and general API security posture. No exploitation, bypass attempts, or harmful actions were performed.

The selected API responded successfully to unauthenticated requests and exposed structured user metadata such as phone numbers, websites, and company information. Based on the observations, several medium and low severity risks were identified.

Objective

The purpose of this task was to simulate the work of an Application Security Consultant by reviewing a public API and preparing a professional risk analysis report.

Goals included:

- Inspecting public API endpoints

- Reviewing authentication requirements

- Analyzing response data exposure

- Identifying common API security risks

- Assessing business impact

- Recommending remediation steps

JSONPlaceholder - Free Fake RE | Grow | LinkedIn | FUTURE_CS_03/README.md at

jsonplaceholder.typicode.com

Check my new project MistCSS write React components with 50% less code

JSONPlaceholder

Guide Sponsor this project Blog My JSON Server

{JSON} Placeholder

Free fake and reliable API for testing and prototyping.

Powered by JSON Server + LowDB.

Serving ~3 billion requests each month.

filestack
All-in-one solution for upload. Process and transform files with AI capabilities. Get started.
www.filestack.com
Ads by EthicalAds

30°C Partly cloudy Search ENG IN 22:24 28-04-2026

Target API Information

API Name: JSONPlaceholder

Type: Public Demo REST API

Base URL:

https://jsonplaceholder.typicode.com

Endpoint Tested: https://jsonplaceholder.typicode.com/users

Scope of Assessment

Included

- Public endpoints only

- Read-only GET requests

- Header inspection

- Response body review

- Authentication verification

- Risk classification

Excluded

- Exploitation attempts

- Login bypass testing

- Vulnerability exploitation

- Denial of Service testing

- Production system attacks

Tools Used

- Postman

- Browser Developer Tools

- GitHub Documentation

- Markdown / PDF Reporting Tools

Methodology

The following methodology was used during the assessment:

1. Selected a safe public API designed for learning.

2. Sent HTTP GET requests using Postman.

3. Verified server response status codes.

4. Reviewed response data fields.

5. Checked if authentication tokens were required.

6. Observed access behavior of public resources.

7. Mapped findings to common API risks.

8. Prepared remediation recommendations.

Evidence Collected

During testing, the endpoint returned a successful HTTP 200 OK response and exposed structured JSON data containing:

- Phone number

- Website

- Company details

- User profile metadata

No authentication token or login process was required to retrieve the data.

Risk Findings

Finding 1: Unauthenticated Access to Endpoint

Severity: Medium

Description

The tested endpoint returned user-related data without requiring any authentication token, session, or API key.

Risk

If similar behavior exists in production systems, unauthorized users may access internal data without verification.

Business Impact

- Public data scraping

- Automated abuse

- Reduced trust in platform security

- Increased attack surface

Recommendation

Require token-based authentication for user-related endpoints and restrict public access where unnecessary.

Finding 2: Excessive Data Exposure

Severity: Medium

Description

The API response included multiple fields such as phone number, website, and company information.

Risk

Returning unnecessary data increases privacy and reconnaissance risk.

Business Impact

- Spam targeting

- Phishing preparation

- Data harvesting

- Privacy concerns

Recommendation

response filtering and return only minimum required fields based on user role.

Finding 3: Predictable Resource Enumeration

Severity: Low

Description

Public APIs using numeric IDs may allow sequential access to records.

Risk

Attackers may automate requests to enumerate multiple records.

Business Impact

- Bulk data collection

- Comp

Recommendation

Use access checks for object-level authorization and monitor enumeration patterns.

Finding 4: Missing Rate Limiting Indicators

Severity: Low

Description

No visible request throttling controls were observed during limited testing.

Risk

Attackers may automate repeated requests.

Business Impact

- Resource abuse

- Increased bandwidth costs

- Performance degradation

Recommendation

Implement API rate limiting, quotas, and anomaly detection

Risk Summary Table

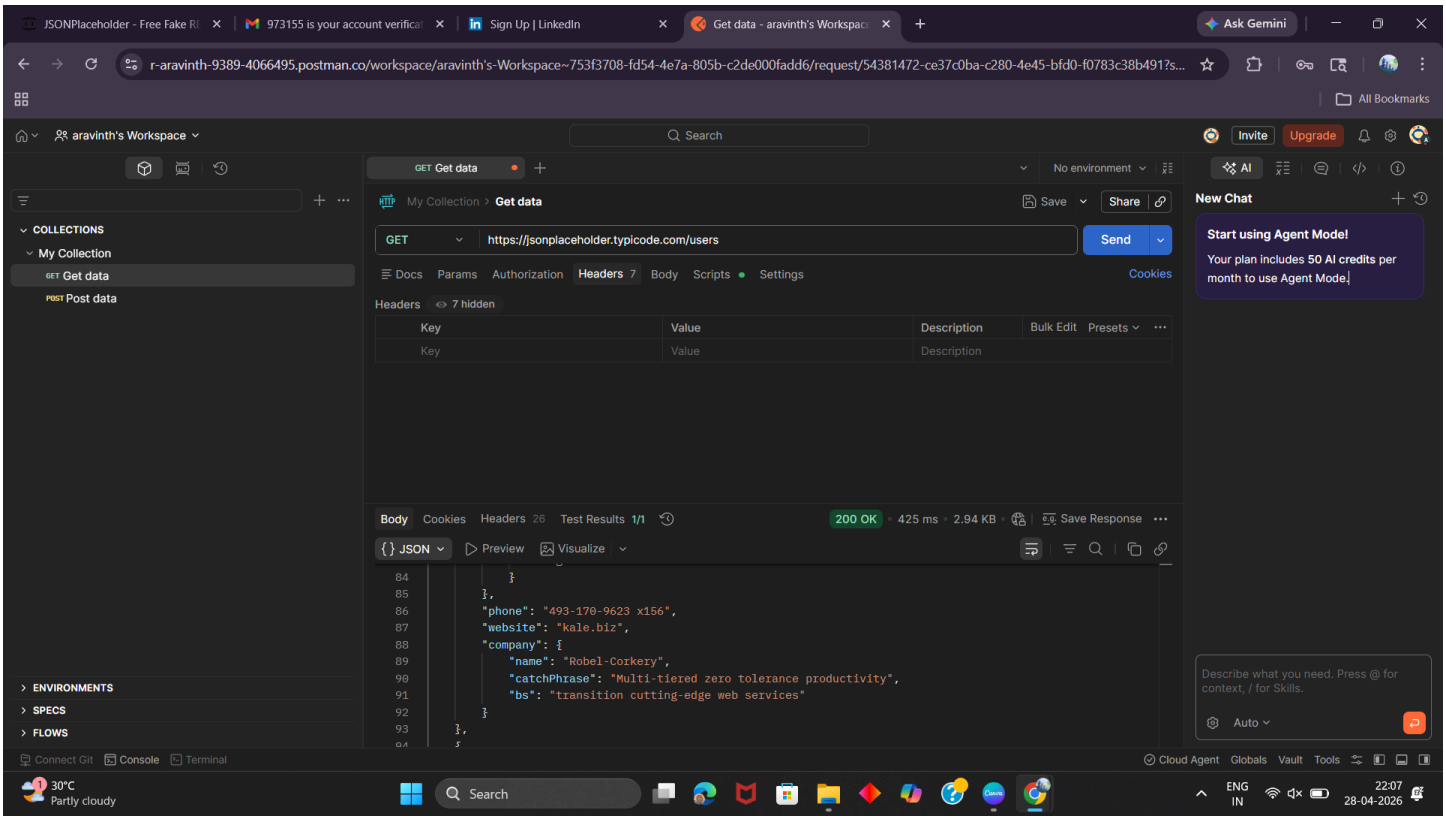
Finding| Severity| Priority

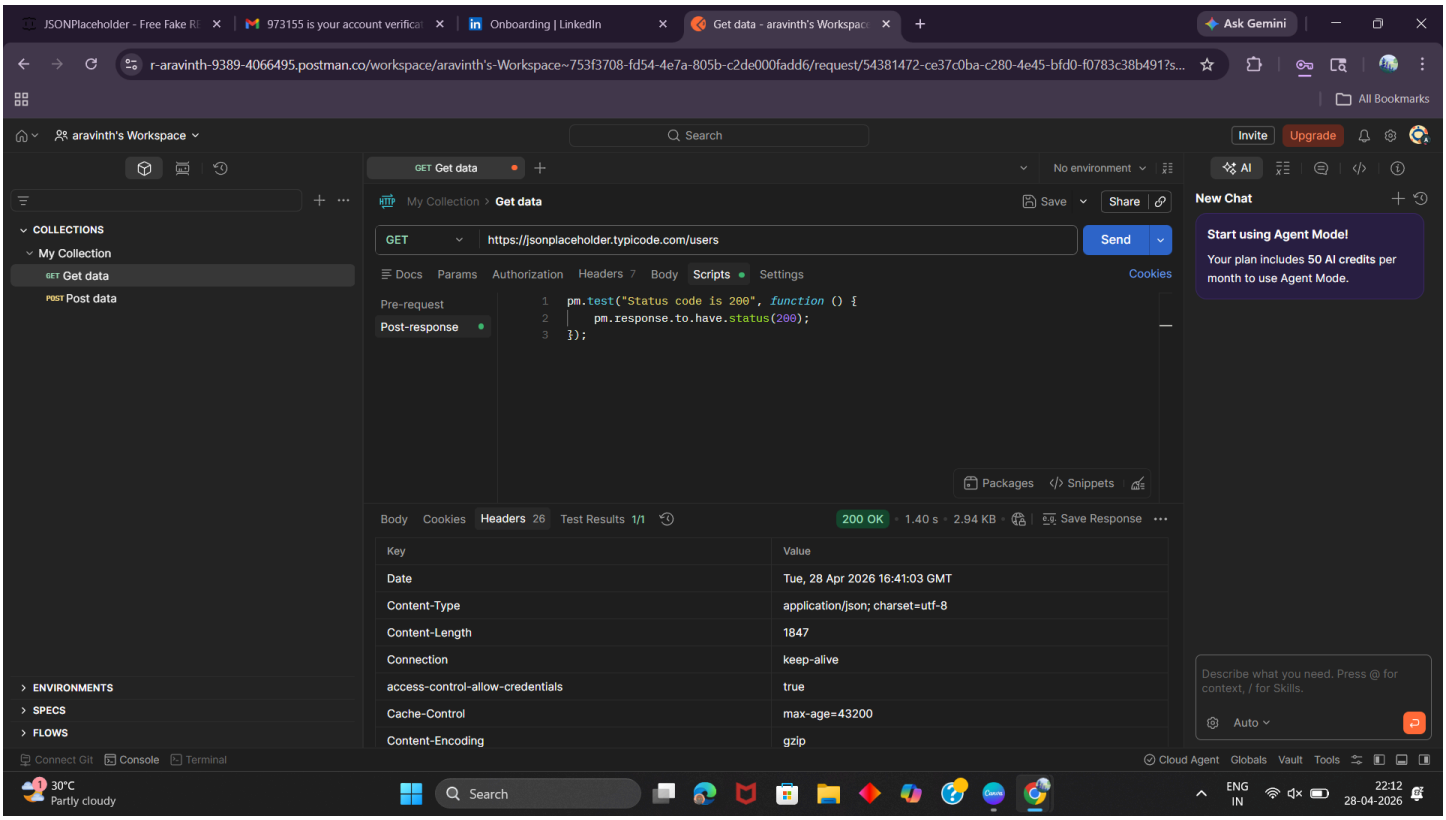
Unauthenticated Access| Medium| High

Excessive Data Exposure| Medium| High

Predictable Enumeration| Low| Medium

Missing Rate Limiting| Low| Medium


JSONPlaceholder - Free Fake RE
973155 is your account verificat
Sign Up | LinkedIn
Get data - aravinth's Workspac
Ask Gemini
r-aravinth-9389-4066495.postman.co/workspace/aravinth's-Workspace~753f3708-fd54-4e7a-805b-c2de000fadd6/request/54381472-ce37c0ba-c280-4e45-bfd0-f0783c38b491?s...
All Bookmarks
aravinth's Workspace
Search
Invite
Upgrade
GET Get data
No environment
COLLECTIONS
My Collection
GET Get data
POST Post data
My Collection > Get data
Save
Share
GET
https://jsonplaceholder.typicode.com/users
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Headers 7 hidden
Key
Value
Description
Bulk Edit
Presets
Body
Cookies
Headers 26
Test Results 1/1
200 OK
425 ms
2.94 KB
Save Response
JSON
Preview
Visualize
"phone": "493-170-9623 x156",
"website": "kale.biz",
"company": {
"name": "Robel-Corkery",
"catchPhrase": "Multi-tiered zero tolerance productivity",
"bs": "transition cutting-edge web services"
ENVIRONMENTS
SPECS
FLOWS
New Chat
Start using Agent Mode!
Your plan includes 50 AI credits per month to use Agent Mode.
Describe what you need. Press @ for context, / for Skills.
Auto
Connect Git
Console
Terminal
Cloud Agent
Globals
Vault
Tools
30°C
Partly cloudy
Search
ENG
IN
22:07
28-04-2026


JSONPlaceholder - Free Fake RE
973155 is your account verificat
Onboarding | LinkedIn
Get data - aravinth's Workspac
Ask Gemini
r-aravinth-9389-4066495.postman.co/workspace/aravinth's-Workspace~753f3708-fd54-4e7a-805b-c2de000fadd6/request/54381472-ce37c0ba-c280-4e45-bfd0-f0783c38b491?s...
All Bookmarks
aravinth's Workspace
Search
Invite
Upgrade
GET Get data
No environment
COLLECTIONS
My Collection
GET Get data
POST Post data
My Collection > Get data
Save
Share
GET
https://jsonplaceholder.typicode.com/users
Send
Docs
Params
Authorization
Headers 7
Body
Scripts
Settings
Cookies
Pre-request
Post-response
pm.test("Status code is 200", function () {
pm.response.to.have.status(200);
});
Packages
Snippets
Body
Cookies
Headers 26
Test Results 1/1
200 OK
1.40 s
2.94 KB
Save Response
Key
Value
Date
Tue, 28 Apr 2026 16:41:03 GMT
Content-Type
application/json; charset=utf-8
Content-Length
1847
Connection
keep-alive
access-control-allow-credentials
true
Cache-Control
max-age=43200
Content-Encoding
gzip
ENVIRONMENTS
SPECS
FLOWS
New Chat
Start using Agent Mode!
Your plan includes 50 AI credits per month to use Agent Mode.
Describe what you need. Press @ for context, / for Skills.
Auto
Connect Git
Console
Terminal
Cloud Agent
Globals
Vault
Tools
30°C
Partly cloudy
Search
ENG
IN
22:12
28-04-2026

Overall Security Assessment

The tested API is intentionally public and suitable for development practice. However, if the same behaviors were present in a real SaaS production environment, they would require remediation.

The most important controls for production APIs are:

- Authentication

- Authorization

- Least privilege responses

- Rate limiting

- Logging and monitoring

Key Recommendations

1. Enforce authentication using secure tokens.

2. Implement object-level authorization checks.

3. Return only necessary response fields.

4. Apply rate limiting and abuse controls.

5. Enable centralized logging and alerting.

6. Review APIs against OWASP API Security Top 10.

Conclusion

This assessment successfully demonstrated the process of conducting an API Security Risk Analysis using safe, ethical methods. The project reflects practical skills required in AppSec, SaaS Security, and Security Consulting roles.

The exercise also highlights how publicly accessible APIs can create security and privacy risks when strong controls are not applied.